SEMANA 14 · IA EN SEGURIDAD DE REDES

La inteligencia artificial entra a la red: dos caras, un mismo motor

Parte 1 de 4 · Unidad 3

Ing. Rodolfo Cañas Cervantes
Universidad de la Costa (CUC) · Ingeniería de Sistemas
Semana 14 · Periodo 2026-2 · Barranquilla, Colombia

De qué habla esta semana: la misma tecnología que defiende también ataca, y el criterio para usarla bien es la verificación humana.

De la regla fija al modelo que aprende

En la semana trece viste umbrales escritos a mano; hoy el modelo los aprende del tráfico.

Dos mundos para la misma meta: detectar el ataque a tiempo

REGLAS FIJAS · S13

- threshold en Suricata
- limit rate over en nftables
- detectan lo conocido
- se ajustan a mano

misma meta →

MODELOS · S14

- aprenden la línea base
- detectan lo desconocido
- se recalibran solos
- exigen verificación

La pregunta de la Unidad 3: ¿y si el detector también aprendiera?

El ataque cambia todos los días; el umbral fijo no.

Fuente: elaboración propia a partir de Gartner — Network Detection and Response (glosario), 2026

CONCEPTO

Qué significa IA en esta asignatura

Un modelo no piensa: calcula probabilidades sobre datos, y eso le alcanza para detectar patrones.



ENTRADA · datos

paquetes y flujos

logs y eventos

características numéricas



MODELO

aprende de lo visto

calcula probabilidades

no piensa



SALIDA · decisión

normal o sospechoso

alerta con contexto

requiere verificación

Salida = probabilidad, no certeza absoluta

El valor está en los datos de entrada y en la verificación de la salida.

Fuente: elaboración propia; NIST AI Risk Management Framework 1.0 (2023), función MAP

Cinco palabras que usaremos toda la semana

Modelo, entrenamiento, inferencia, característica y alerta: el vocabulario mínimo para no perderse.

Cinco palabras que usaremos toda la semana



MODELO

programa que aprende

patrones de los datos



ENTRENAMIENTO

mostrar ejemplos

para que aprenda



INFERENCIA

dato nuevo

y respuesta del modelo



CARACTERÍSTICA

cada número que

describe el tráfico



ALERTA

aviso cuando algo

parece sospechoso

Ninguna palabra es exclusiva de la seguridad: cambia el tipo de datos.

Fuente: NIST AI RMF 1.0 (2023); MITRE (matrices ATT&CK y ATLAS) D3FEND (2026)

Fuente: NIST AI Risk Management Framework 1.0 (2023); MITRE D3FEND (2026)

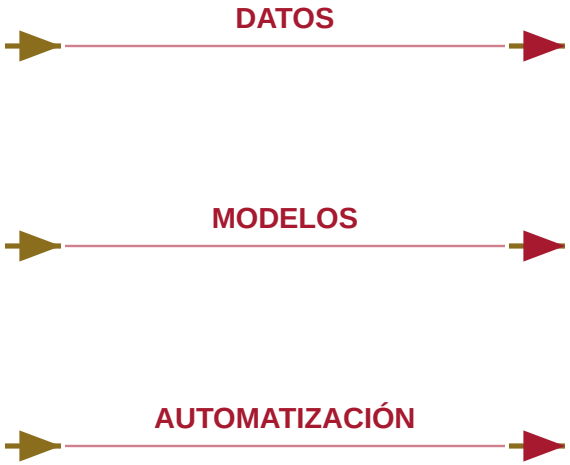
EJE DE LA SEMANA

Dos caras de la misma tecnología

El mismo motor de modelos: una cara protege la red, la otra la explota.

CARA DEFENSIVA · NDR (detección y respuesta en red)

- vigila el tráfico
- aprende lo normal
- alerta lo anómalo
- acelera la respuesta



CARA OFENSIVA · atacante

- phishing personalizado
- voces e imágenes falsas
- evasión de detectores
- automatización de fases

La misma tecnología: la diferencia es la intención y los controles.

Fuente: elaboración propia; MITRE ATLAS (2026) y MITRE ATT&CK Enterprise (2026)

CRITERIO

El marco 4D: cómo evaluar cualquier salida de IA

Delega, describe, discierne y actúa con diligencia; la IA propone, el humano aprueba.



1

1 · DELEGACIÓN

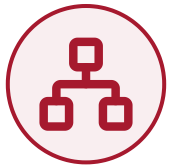
sé consciente de qué cedes y con qué alcance



2

2 · DESCRIPCIÓN

pídele que explique su razonamiento



3

3 · DISCERNIMIENTO

compara con lo que sabes de tu red

4

4 · DILIGENCIA

verifica antes de actuar con impacto

La IA propone, el humano aprueba.

Marco de trabajo del curso para evaluar cualquier salida de un modelo.

Fuente: material de clase, presentación IA Aplicada General (diap. 15-19); NIST AI RMF 1.0 (2023)

Qué hace un NDR en tu red

Observa el tráfico completo, aprende la línea base y detecta lo que no encaja.

NDR: observa el tráfico completo y marca lo que no encaja



TRÁFICO	DATOS	MODELO	ALERTA
sensor en espejo	flujos y estadísticas	clasifica patrones	qué pasó y dónde
captura completa	conversaciones	detecta anomalías	severidad
sin firmas previas	línea base normal	reduce ruido	requiere análisis

Definición Gartner: análisis del tráfico de red con aprendizaje de máquina o estadística para detectar actividades sospechosas.

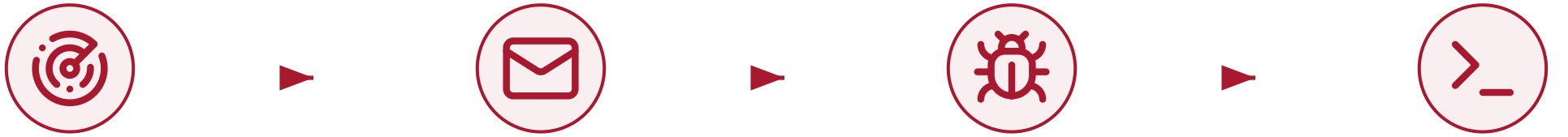
Detecta comportamiento: un servidor que habla con muchos países, un dispositivo que sale a lo desconocido.

Fuente: Gartner — Network Detection and Response (NDR), glosario (consultado 2026)

La ofensiva también se automatiza

Reconocer, escribir, convencer, evadir: todas las fases de la cadena de ataque tienen IA.

La IA acelera cada fase de la cadena de ataque



RECONOCIMIENTO	ENTREGA	EXPLOTACIÓN	POST-EXPLOTACIÓN
recopila información	correos sin errores	evasión de detectores	moverse sin ruido
T1598: phishing para	contexto local	suplantación de voz	activar datos sensibles
obtener credenciales	escenarios creíbles	deepfakes creíbles	sostener el engaño

Ventaja del atacante: elige cuándo, cómo y contra quién.

Fuente: MITRE ATT&CK Enterprise, T1598; MITRE ATLAS para técnicas sobre sistemas de IA.

Fuente: MITRE ATT&CK Enterprise — técnica T1598 Phishing for Information (2026); MITRE ATLAS (2026)

Los datos son el combustible de todo esto

Sin telemetría de red completa y confiable, ningún modelo aprende bien.

Fuentes de telemetría que alimentan los modelos

Flujos NetFlow
quién habló con quién
volumen y puertos

Firewall
reglas coincidentes
conex. bloqueadas

Servidores
logs de acceso
fallos de auth

IDS/IPS
alertas de firmas

DNS
consultas y dominios

cada fuente da una vista parcial



DATOS NORMALIZADOS → MODELO

cada red tiene su propia línea base
datos malos producen modelos malos

Un modelo entrenado para una red no sirve tal cual en otra: la línea base es propia.

Fuente: elaboración propia; MITRE ATT&CK — matrices Enterprise (2026)

Por qué las reglas fijas se quedan cortas

Un umbral detecta lo que definiste; un modelo detecta lo que no esperabas.



REGLAS FIJAS · S13

detectan lo que definiste
se ajustan a mano
ciegas ante lo nuevo
certeza sobre lo conocido

+



MODELO · S14

aprenden lo normal
marcan lo que no encaja
cubren lo desconocido
exigen verificación

El mismo lab de DoS: Suricata con threshold + nftables con limit rate over, y encima un modelo que aprende.

JUNTOS: cobertura total

Fuente: elaboración propia a partir de la guía del Lab 6 (Suricata con threshold y nftables con limit rate over)

EVOLUCIÓN

De los firewalls con reglas al SOC (centro de operaciones de seguridad) con IA

La seguridad de red evolucionó de puertas a guardianes que aprenden.



Ninguna etapa borra a la anterior: se suman sobre la misma red.

De defensa reactiva (esperar la firma) a defensa que entiende el comportamiento de la red.

El SOC moderno apoya al analista con IA, pero la decisión final es humana (NIST SP 800-61r3).

Fechas aproximadas ilustrativas de la evolución de la seguridad de red.

Fuente: elaboración propia; NIST SP 800-61 Rev. 3 (2025) para la etapa de respuesta

Dónde ya se usa la IA en seguridad de red

Detección de intrusiones, protección de correo, filtrado web y respuesta automatizada: no es futuro.

Dónde ya se usa la IA en seguridad de red



INTRUSIONES

modelos que complementan las firmas conocidas



CORREO

clasifica por comportamiento



FILTRADO WEB

categorías sin depender de la URL exacta



ANOMALÍAS

tráfico interno el corazón del NDR



RESPUESTA

acciones previamente autorizadas

En los cinco casos la IA complementa un control existente, no lo reemplaza.

Fuente: CISA (2026); Gartner — NDR (2026); MITRE D3FEND (2026)

Fuente: CISA — página de IA (2026); Gartner — NDR (2026); MITRE D3FEND (2026)

RIESGOS

Los riesgos de usar IA en seguridad

Alucinación, evasión adversarial y envenenamiento de datos: la IA también falla.



ALUCINACIÓN

el modelo inventa

datos o eventos

persigues fantasmas



EVASIÓN ADVERSARIAL

el atacante estudia

qué mira el modelo

y lo modifica



ENVENENAMIENTO

contaminan los datos

de entrenamiento

el modelo aprende mal

OWASP (seguridad de aplicaciones web) LLM01: la inyección de instrucciones es el riesgo número uno

de las aplicaciones con modelos de lenguaje.

Usar IA sin conocer sus fallas es cambiar un problema por otro.

Fuente: OWASP Top 10 for LLM Applications (2025), LLM01; MITRE ATLAS — técnicas adversarias (2026)

El panorama 2026: la IA ya está en la pelea

Organismos oficiales advierten que la IA amplifica el phishing y las estafas de voz.

Lo que dicen los organismos oficiales

ENISA · Threat Landscape 2024

la IA amplifica el volumen
del phishing y de la
ingeniería social
informe anual de amenazas

CISA · IA en ciberseguridad

punto de entrada a guías
respuesta a incidentes
uso responsable de IA
avisos y recomendaciones

Dirección verificable: el phishing es más difícil de notar y las voces falsas suenan reales.

Se citan las fuentes; sin cifras no verificadas.

Fuente: ENISA Threat Landscape 2024; CISA — página de IA (2026)

SÍNTESIS

Lo que queda de la Parte 1

Tres ideas: misma tecnología, datos por delante, verificación humana por encima de todo.



1 · MISMA TECNOLOGÍA

defiende y ataca

la diferencia es quién

la opera y con qué fin



2 · DATOS PRIMERO

sin telemetría buena

no hay modelo bueno

la línea base es propia



3 · VERIFICACIÓN HUMANA

delegar con criterio

describir y discernir

la IA propone, tú apruebas

Con esto pasamos a la cara defensiva: el NDR con aprendizaje de máquina.

Fuente: elaboración propia; NIST AI RMF 1.0 (2023)

SEMANA 14 · PARTE 2

NDR con machine learning: la defensa que aprende de tu red

Parte 2 de 4 · Unidad 3

Ing. Rodolfo Cañas Cervantes
Universidad de la Costa (CUC) · Ingeniería de Sistemas
Semana 14 · Periodo 2026-2 · Barranquilla, Colombia

Cómo un sistema de detección de red aprende la línea base y detecta anomalías; el puente hacia el Laboratorio 7.

CONCEPTO

Qué es una anomalía de red

Anomalía es lo que se desvía de la línea base de tu red, no lo que se parece a un ataque conocido.

Anomalía: lo que se desvía de la línea base de TU red



La línea base es propia: el modelo se entrena con tus datos.

No es un catálogo genérico de ataques: es el retrato de lo que te parece normal a ti.

Fuente: elaboración propia; MITRE D3FEND — contramedidas de detección (2026)

El pipeline NDR: del enlace al veredicto

Captura, enriquece, modela y decide: cuatro etapas encadenadas dentro del sistema.

Pipeline NDR: del enlace al veredicto



1 · CAPTURA

sensor en puerto espejo

copia el tráfico

sin afectar al enlace

2 · CARACTERÍSTICAS

quiénes y en qué puertos

volumen y ritmo

tráfico → números

3 · MODELO

clasifica cada flujo

asigna probabilidad

marca sospechosos

4 · DECISIÓN

alerta con contexto

llega al analista

la acción es humana

En la detección inicial el modelo no bloquea: prioriza y avisa.

La decisión de acción la toma el equipo, para no dañar tráfico legítimo.

El orden importa: sin una captura confiable, ninguna de las tres etapas siguientes sirve.

Fuente: elaboración propia a partir de la definición de NDR de Gartner (2026)

Cómo se aprende una línea base

Se observa el tráfico durante días y semanas; el modelo aprende el patrón diario y el semanal.

Cómo se aprende una línea base



OBSERVAR

varias semanas

de tráfico real



RITMO DIARIO

horas pico

y horas muertas



RITMO SEMANAL

martes distinto

de domingo



LÍNEA BASE

el patrón que

el modelo aprende

Si solo mirara un día, marcaría como anómalo lo normal de otro día.

Fuente: elaboración propia a partir de Gartner — NDR (2026)

Fuente: elaboración propia a partir de la definición de NDR de Gartner (2026)

APRENDIZAJE

Supervisado o no supervisado: dos caminos

Con etiquetas se clasifica; sin etiquetas se busca lo raro. Cada uno acumula un tipo de error.

SUPERVISADO

datos etiquetados

este flujo era ataque

este era normal

preciso, exige etiquetas

clasificar: ¿es ataque o no es?

NO SUPERVISADO

sin etiquetas

agrupa lo parecido

marca lo aislado

descubre lo nuevo

descubrir: ¿qué es lo raro de mi red?

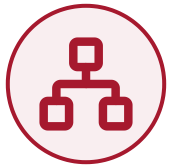
Un sistema maduro combina ambos caminos en paralelo.

Fuente: elaboración propia; NIST AI RMF 1.0 (2023)

De flujos a números: las características

Duración, volumen, puertos y ritmo: el tráfico crudo se convierte en columnas que el modelo entiende.

El tráfico se convierte en números: características del flujo



TRÁFICO CRUDO

capturas de red

pcap y flujos

no lo entiende el modelo



CARACTERÍSTICAS

duración

paquetes suben y bajan

bytes transferidos

ratio SYN/ACK

varianza del payload



MODELO

lee vectores

clasifica flujos

calcula riesgo

Un SYN flood altera la proporción de medias conexiones; un escaneo cambia el ritmo de conexiones cortas.

Estas características son la materia prima de cualquier detección por comportamiento.

Fuente: elaboración propia; Gartner — NDR (2026)

El modelo se evalúa, no se adora

Precisión y recuerdo miden cuánto ruido genera y cuántos ataques deja pasar.

Dos métricas que deciden si el modelo sirve

PRECISIÓN

de las alertas que dio
¿cuántas eran reales?
baja precisión = ruido
equipo persigue falsos

RECUERDO

de los ataques reales
¿cuántos atrapó?
bajo recuerdo = ciego
ataques que pasan de largo

Apretar reduce falsos negativos pero genera más ruido; aflojar reduce ruido pero deja pasar ataques.

El analista calibra ese punto según la realidad de su organización.

Las mismas dos métricas juzgan cualquier detector: también los que verás en la industria.

Fuente: elaboración propia; NIST AI RMF 1.0 (2023), función MEASURE

Anomalía de comportamiento: usuarios y equipos

La IA no solo mira paquetes: aprende cómo se comporta cada usuario y cada dispositivo.

Cada usuario y dispositivo tiene un perfil; lo raro sale del cuadro

comparación contra el propio patrón



PERFIL HABITUAL

analista: 8 a 6 de la tarde

equipos: servidores y puertos

respaldos: de noche, interno

perfil normal: nunca se desvía



COMPORTAMIENTO RARO

analista a las 2 de la mañana

equipo hacia país lejano

descarga masiva nocturna

desviación marcada por el modelo

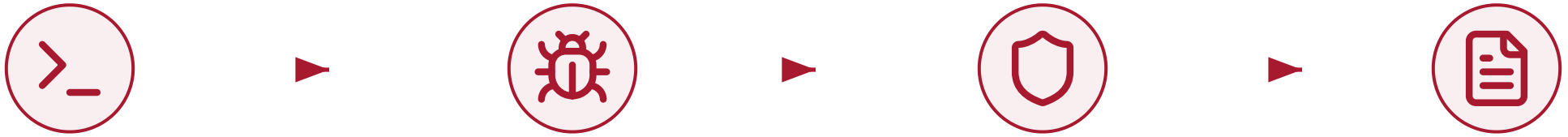
Lo raro puede ser un ataque o un empleado en vacaciones: el contexto lo decide.

Fuente: elaboración propia; Gartner — NDR (2026)

El Laboratorio 7: prompt injection y defensas

La guía ya está publicada: montas un asistente con un secreto ficticio, lo atacas con cinco técnicas y lo defiendes con tres controles.

Laboratorio 7 · montar, atacar, defender y documentar



1 · MONTAJE

EC2 Ubuntu 24.04

Ollama qwen2.5:1.5b

un asistente propio

2 · ATAQUES

cinco técnicas

directa e indirecta

rol, codificación, turnos

3 · DEFENSAS

delimitadores

filtro de entrada y salida

secreto fuera del prompt

4 · INFORME

tabla antes/después

nueve capturas

PDF en el aula

El secreto es inventado (CUPON-INTERNO-2026) y todo corre en tu propia instancia.

Laboratorio 7 · 10 % del Corte 3 · individual · PDF hasta el 29-nov-2026

Fuente: guía del Laboratorio 7 — prompt injection y defensas; OWASP Top 10 for LLM Applications (2025), LLM01

La fatiga de alertas: el costo del ruido

Un modelo que avisa demasiado enseña al equipo a ignorarlo, y ese es el peor resultado posible.

La fatiga de alertas: el costo del ruido



MUCHAS ALERTAS

el volumen

sube



ATENCIÓN

la que recibe

cada una baja



CONFIANZA

el equipo empieza

a ignorarlas



CALIBRAR

umbral, agrupación

y prioridad

Un modelo con mucho recuerdo y poca precisión puede ser peor que no tener modelo.

Fuente: NIST SP 800-61 Rev. 3 (2025); elaboración propia

Fuente: NIST SP 800-61 Rev. 3 (2025); elaboración propia

Los límites del aprendizaje: evasión y deriva

El modelo envejece y el atacante aprende a esquivarlo; por eso se reentrena y se audita.

EVASIÓN ADVERSARIAL

el atacante observa

qué señales mira el modelo

y las modifica

DERIVA DE DATOS

la red cambia cada semana

el modelo envejece

ya no reconoce lo normal

CICLO DE AUDITORÍA

monitorear rendimiento

reentrenar con datos nuevos

decidir cuándo confiar

El modelo no es una instalación de una sola vez: es un ciclo continuo.

Fuente: MITRE ATLAS (evasión de sistemas de IA, 2026).

Fuente: MITRE ATLAS — evasión de sistemas de IA (2026); NIST AI RMF 1.0 (2023)

INTEGRACIÓN

NDR dentro del SOC: con SIEM y SOAR (automatización de respuesta)

El NDR no está solo: alimenta al SIEM y dispara procesos de respuesta sin reemplazar al analista.



NDR	SIEM	SOAR	ANALISTA
detecta con ML	correlaciona fuentes	ejecuta pasos seguros	valida y decide
alerta con contexto	cruza logs y eventos	según lo autorizado	autoridad final
cubre lo desconocido	visión central	acelera la respuesta	documenta

Detectar, correlacionar, automatizar pasos seguros y validar: cada capa hace una cosa.

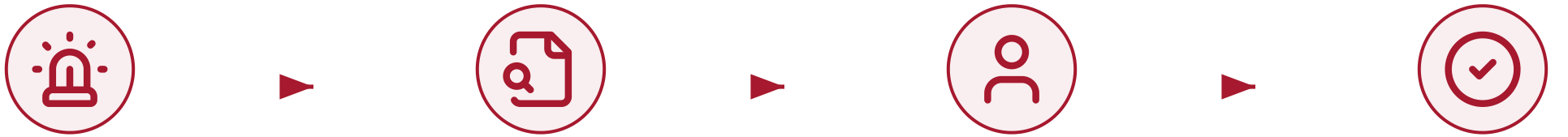
NIST SP 800-61 Rev. 3: la tecnología acelera, la verificación y la autoridad son humanas.

Fuente: NIST SP 800-61 Rev. 3 (2025) — respuesta a incidentes; Gartner — NDR (2026)

VERIFICACIÓN

La alerta no es el veredicto

Cada alerta relevante pasa por análisis humano: contexto, evidencia y decisión documentada.



1 · ALERTA

llega del NDR

con probabilidad

y contexto

2 · CONTEXTO

qué, quién, cuándo

cruzar con el SIEM

perfil del afectado

3 · ANÁLISIS HUMANO

discierne con el marco 4D

compara con la red

decide incidente o no

4 · DECISIÓN

documenta

actúa o descarta

retroalimenta

La alerta propone; el analista dispone.

Trazabilidad: cada decisión se documenta para ajustar umbrales y el propio modelo.

Fuente: NIST SP 800-61 Rev. 3 (2025); marco 4D del curso (diap. 15-19)

CASO

Anomalía en una tarde corriente

Caso ilustrativo: las alertas de una universidad del Caribe y el camino hasta descartarlas.

Caso ilustrativo · una universidad del Caribe (no es una institución real)



ALERTA DEL NDR

pico de tráfico saliente

equipos de administración

probabilidad alta: exfiltración

se verifica antes de actuar



QUÉ SE HIZO

no se bloqueó a ciegas

se revisó equipo y destino

diálogo con el área afectada

Resultado: era una actualización autorizada del sistema de matrículas. Alerta descartada.

La próxima semana, el mismo patrón sin autorización se detectó y se respondió a tiempo.

El valor del proceso no está solo en acertar, sino en entender tu propia red.

Fuente: caso ilustrativo de clase, sin datos de una institución real

SÍNTESIS

Lo que queda de la Parte 2

Pipeline, métricas y límites: la defensa con ML se entrena, se mide y se audita.



1 · PIPELINE

tráfico → características

→ modelo → alerta

con tecnología y datos



2 · SE MIDE

precisión y recuerdo

matriz de confusión

se reentrena al cambiar



3 · SE AUDITA

la alerta llega al humano

contexto y decisión

nada se aplica a ciegas

Con la defensa clara, pasamos a la ofensiva: phishing, deepfakes e inyección de instrucciones.

Fuente: elaboración propia; NIST AI RMF 1.0 (2023)

SEMANA 14 · PARTE 3

Ataques potenciados por IA: phishing, voces falsas y prompt injection

Parte 3 de 4 · Unidad 3

Ing. Rodolfo Cañas Cervantes
Universidad de la Costa (CUC) · Ingeniería de Sistemas
Semana 14 · Periodo 2026-2 · Barranquilla, Colombia

La cara ofensiva: cómo la IA hace más creíble el engaño y cómo la inyección de instrucciones ataca a los propios modelos.

El objetivo sigue siendo la persona

Antes que la técnica, el engaño explota autoridad, urgencia y confianza: la IA solo lo hace más fino.

El objetivo sigue siendo la persona



AUTORIDAD

viene de alguien

que puede ordenar



URGENCIA

hay plazo

se pierde algo



CONFIANZA

encaja con lo que

esperas recibir



IA

perfecciona el

contexto, no el gatillo

La IA no inventó el engaño: lo volvió más fino y más barato.

Fuente: ENISA Threat Landscape 2024; CISA (2026)

Fuente: ENISA Threat Landscape 2024; CISA — página de IA (2026)

AMENAZA

El phishing ya no se delata solo

La IA elimina las señales clásicas: ortografía, contexto y personalización ahora son creíbles.

ANTES · señales de alarma

errores de ortografía

saludo genérico

traducción rara

remitente sospechoso

AHORA · con IA generativa

sin faltas

tu nombre y tu empresa

contexto local actual

remitente creíble

la ventaja del ojo humano se perdió

MITRE ATT&CK T1598 · phishing para obtener información

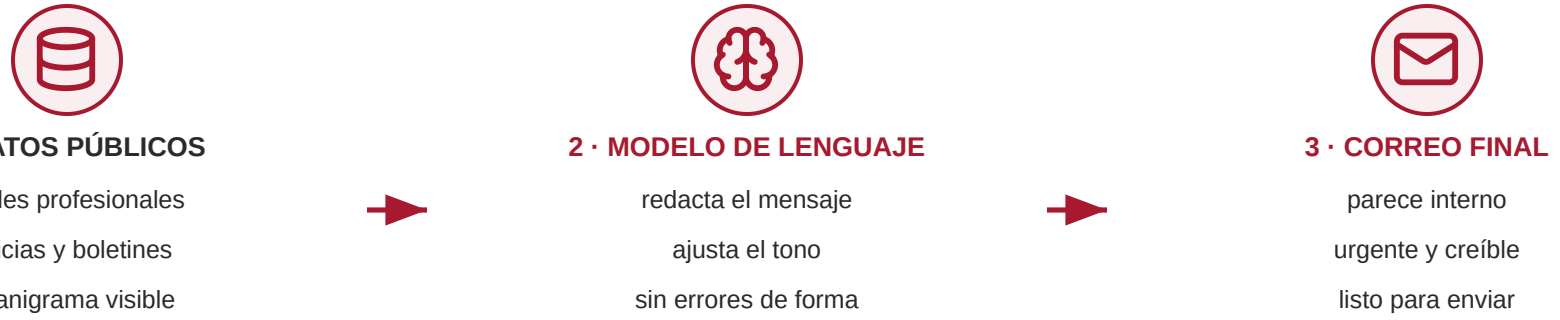
Ya no se detecta por la forma del correo, sino por el fondo y por el canal.

Fuente: MITRE ATT&CK T1598 (2026); CISA — página de IA (2026)

MECÁNICA

Cómo se fabrica un correo creíble en segundos

Datos públicos del objetivo más un modelo: el correo se escribe solo, con tu contexto laboral.



El volumen sube y la personalización se automatiza: el filtro por forma ya no alcanza.

La vacuna: sospecha razonable y confirmación por otro canal.

Fuente: MITRE ATT&CK T1598; elaboración propia.

Fuente: MITRE ATT&CK Enterprise — técnica T1598 (2026); elaboración propia

VISHING

La voz también se falsifica: vishing con IA

Con pocos segundos de tu voz, un modelo puede hablar como tú; la llamada ya no se verifica por el oído.



MUESTRA DE VOZ

segundos de audio

de una charla o video

público en internet

CLONACIÓN

imita el timbre

y los giros

del habla

LLAMADA FALSA

suena a tu directora

pide giro urgente

o una clave

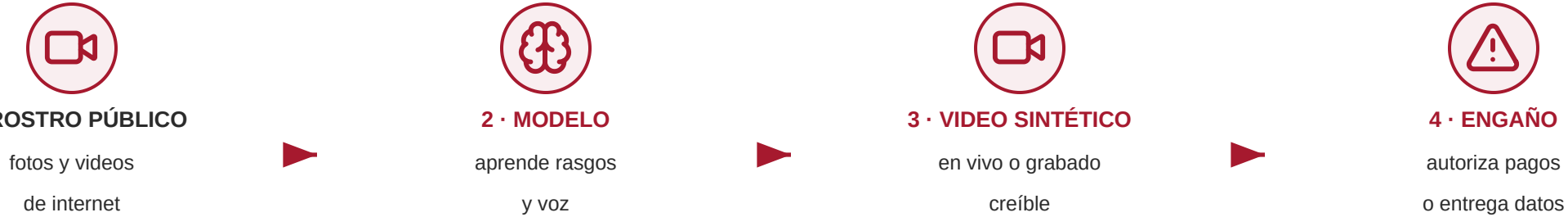
El oído ya no autentica: confirmar por un canal que el atacante no controla.

Fuente: CISA — IA generativa (2026); ENISA Threat Landscape 2024.

Fuente: CISA — página de IA (2026); ENISA Threat Landscape 2024

Rostros falsos: deepfakes en video

Una videollamada ya no garantiza que la persona al otro lado sea quien dice ser.



Ver la cara ya no es autenticar.

En operaciones sensibles se confirma por protocolo, no por imagen.

Caso ilustrativo de clase, sin datos de una empresa real.

Fuente: CISA (2026); ENISA Threat Landscape 2024.

Fuente: CISA — IA generativa (2026); ENISA Threat Landscape 2024; caso ilustrativo sin datos reales

CEO fraud y compromiso de correo empresarial

Cuando el atacante suplanta a un directivo, el engaño se apoya en la autoridad y en la urgencia.

Compromiso de correo empresarial: cuatro pasos que se repiten



1 · RECONOCER

quién decide

quién paga



2 · SUPLANTAR

nombre del directivo

correo parecido



3 · URGIR

confidencialidad

plazo corto



4 · COBRAR

giro o factura

a cuenta ajena

Doble verificación para giros · cultura de no decidir bajo presión

Un empleado que duda y confirma por teléfono oficial salva a la empresa.

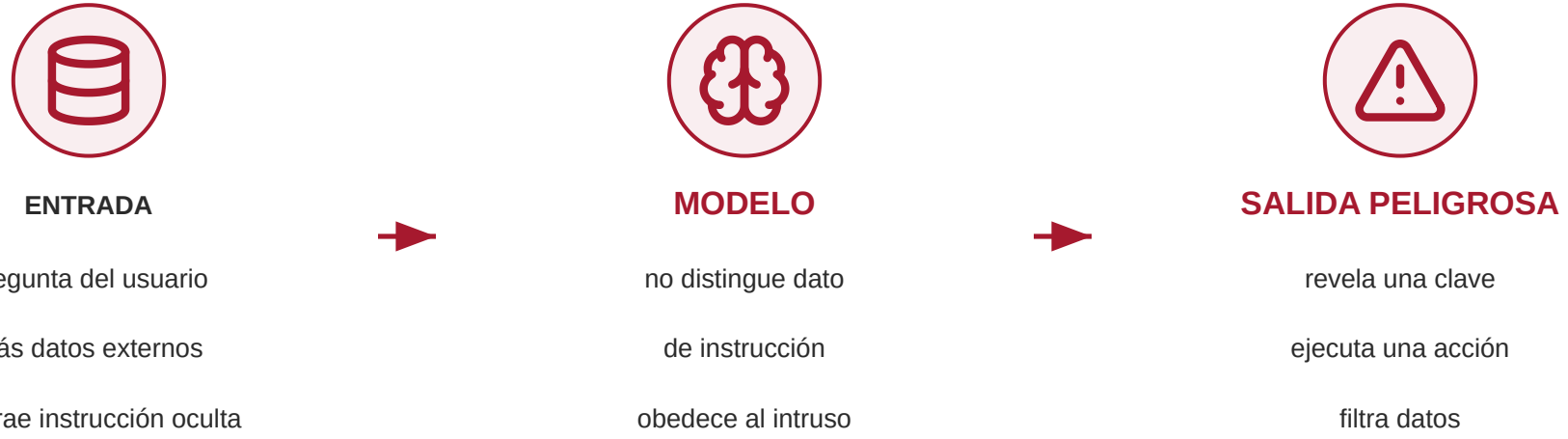
Fuente: IC3 (portal del FBI), consultado 2026.

Patrón documentado; el caso concreto es ilustrativo, sin cifras.

Fuente: IC3 — Internet Crime Report (portal FBI, consultado 2026); caso ilustrativo

Prompt injection: atacar al propio modelo

LLM01 de OWASP: instrucciones escondidas en los datos pueden secuestrar la respuesta del modelo.



OWASP LLM01: la inyección de instrucciones es el riesgo número uno
de las aplicaciones con modelos de lenguaje.

Fuente: OWASP Top 10 for LLM Applications (2025), LLM01.

Endurecer el modelo y el flujo

Separar instrucción de datos, delimitar roles y vigilar la salida: tres capas que frenan la inyección.

Tres capas que frenan la inyección de instrucciones



1 · SEPARAR

instrucción del sistema

aislada de los datos

delimitadores y roles



2 · VALIDAR SALIDA

revisar antes de actuar

nada destructivo

sale directo



3 · MÍNIMO PRIVILEGIO

solo lo necesario

sin credenciales

amplias

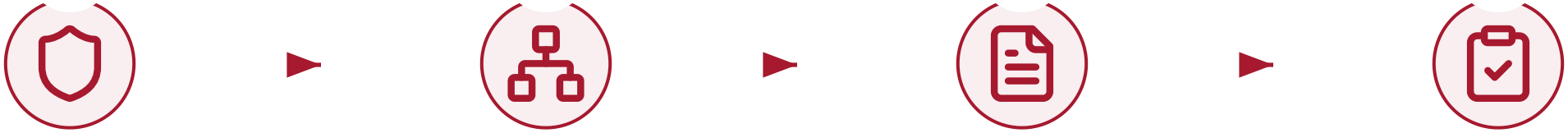
Aunque la instrucción entre, la aplicación no cede el mando.

Entrada saneada · modelo contenido · salida inspeccionada.

Fuente: OWASP Top 10 for LLM Applications (2025), LLM01; MITRE ATLAS.

El marco 4D como escudo personal

Ante la duda: delega poco, exige descripción, discierne y verifica por otro canal.



1

DELEGA

no cedas valor

a la urgencia

2

DESCRIBE

pide un dato que

solo el real tendría

3

DISCIERNE

¿canal correcto?

¿encaja con la política?

4

VERIFICA

confirma por canal

oficial antes de actuar

Cada paso es una puerta: el atacante prueba muchas, basta una cerrada.

El método es hábito, no excepción.

Fuente: material de clase, IA Aplicada General (diap. 15-19).

Fuente: material de clase, presentación IA Aplicada General (diap. 15-19)

Contramedidas organizacionales

Políticas de doble verificación, canales alternos y autenticación resistente al phishing.

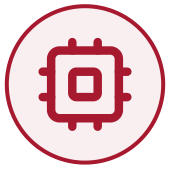


POLÍTICA

doble verificación

para giros y compras

procedimientos escritos



TECNOLOGÍA

autenticación resistente

al phishing

correo autenticado



PROCEDIMIENTO

canal alterno oficial

número verificado

escalamiento claro

Ninguna capa es infalible; juntas cambian la economía del ataque.

La decisión crítica pasa siempre por un punto que el atacante no controla.

Fuente: OWASP LLM (2025); CISA (2026); NIST SP 800-63B (2017).

Las técnicas ya están catalogadas

MITRE ATLAS documenta cómo se ataca a los sistemas de IA: reconocimiento, evasión y abuso del modelo.

MITRE ATT&CK

cadena de ataque clásica

reconocimiento y acceso

movimiento lateral

MITRE ATLAS

ataques a sistemas de IA

evasión y envenenamiento

abuso e inyección

La lista de chequeo se arma con las dos matrices: atacante clásico y adversario de la IA.

Vocabulario común y controles accionables.

Fuente: MITRE ATLAS (2026); MITRE ATT&CK Enterprise (2026).

CHECKLIST

Cinco preguntas antes de confiar en un mensaje

Remitente real, canal, urgencia, petición y verificación: un filtro de treinta segundos.

Cinco preguntas antes de confiar



1 ¿REMITENTE?

mira la dirección completa



2 ¿CANAL?

habitual o uno raro



3 ¿PRISA?

urgencia o autoridad



4 ¿QUÉ PIDE?

un dato, un pago o un clic



5 ¿VERIFICO?

por un canal que yo controle

Si alguna respuesta deja dudas, no respondas por el mismo hilo.

Fuente: material de clase; CISA (2026); OWASP LLM Top 10 (2025)

RESPUESTA

Si ya hiciste clic: qué hacer en la primera hora

Aislar, cambiar credenciales, avisar y documentar: la velocidad importa más que la culpa.

Si ya hiciste clic: la primera hora



AISLAR

desconecta el equipo

sin apagarlo



CREDENCIALES

cámbialas desde

otro dispositivo



AVISAR

seguridad o TI

de inmediato



DOCUMENTAR

qué pasó

y a qué hora

Lo que no está en la lista: culpar. Un equipo que oculta errores produce brechas.

Fuente: NIST SP 800-61 Rev. 3 (2025); IC3 (FBI)

Fuente: NIST SP 800-61 Rev. 3 (2025); IC3 (portal del FBI, consultado 2026)

SÍNTESIS

Lo que queda de la Parte 3

El engaño mejora con IA, pero la verificación humana sigue siendo la última barrera.



PHISHING

sin errores clásicos

el fondo, no la forma



VOZ Y ROSTRO

ver y oír

ya no autentican



PROMPT INJECTION

riesgo de diseño

separar y validar



4D

delegar, describir

discernir, verificar

La verificación humana sigue siendo la última barrera.

Parte 4: la plataforma de red consciente de la IA y el cierre de la unidad.

Fuente: elaboración propia; OWASP Top 10 LLM (2025); CISA — página de IA (2026)

SEMANA 14 · PARTE 4

SASE (acceso seguro al borde) con IA, SOC aumentado y cierre de la semana

Parte 4 de 4 · Unidad 3

Ing. Rodolfo Cañas Cervantes
Universidad de la Costa (CUC) · Ingeniería de Sistemas
Semana 14 · Periodo 2026-2 · Barranquilla, Colombia

Cómo la plataforma de red se vuelve consciente de la IA, cómo cambia el trabajo del analista y qué queda para la semana 15.

CONCEPTO

SASE: red y seguridad como un solo servicio

Secure Access Service Edge: políticas de red y seguridad aplicadas desde la nube, cerca del usuario.

Dónde se aplica el control: sede central vs cerca del usuario

MODELO ANTIGUO

todo el tráfico viaja
hasta el centro de datos
se revisa y se devuelve
lento y ciego en la nube

MODELO SASE

control en la nube
cerca del usuario
misma política en todas partes
red y seguridad como servicio

usuarios en cualquier lugar

la política sigue al usuario

Gartner: convergencia de capacidades de red y seguridad entregadas como servicio.

No es un producto único: es una arquitectura que combina funciones.

Fuente: Gartner — Secure Access Service Edge (SASE), glosario (consultado 2026)

Qué compone una plataforma SASE

Acceso zero trust, firewall en la nube, puerta de enlace web y broker de acceso: cuatro piezas.

Cuatro piezas que comparten una sola política

ACCESO ZERO TRUST

cada conexión se autentica

no se asume confianza por estar dentro

FIREWALL EN LA NUBE

inspecciona el tráfico

hacia internet

PUERTA DE ENLACE WEB

filtra sitios

y contenido

BROKER DE ACCESO

controla aplicaciones privadas

sin exponerlas directamente

Política y datos compartidos: la IA ve patrones que ninguna pieza vería sola.

Fuente: Palo Alto Networks — Cyberpedia, define SASE (consultado 2026); Gartner (2026)

Dónde entra la IA en SASE

Clasificación de tráfico, detección de anomalías y ajuste de políticas con evidencia de cada conexión.

Tres puntos de inserción de la IA en SASE



1 · CLASIFICACIÓN

qué aplicación es
sin depender de puertos
o de listas fijas



2 · ANOMALÍAS

línea base por usuario
accesos raros
en contexto



3 · AJUSTE DE POLÍTICA

propone reglas más finas
con evidencia
de cada conexión

Propone, no impone: la política se cambia con aprobación humana.

Una regla automática mal ajustada puede detener el trabajo de toda la organización.

Fuente: Gartner — SASE (2026); elaboración propia.

Fuente: Gartner — SASE (2026); elaboración propia

El SOC aumentado: qué cambia para el analista

Menos clasificación manual y más investigación: la IA filtra el ruido, el humano juzga el caso.

La jornada del analista, antes y después del apoyo de IA

ANTES

la mayor parte del turno
clasificando alertas
una por una
poco tiempo de investigación

DESPUÉS

triage automático del ruido
foco en investigación
contexto y decisión
la máquina prioriza

La ganancia no es trabajar menos: es trabajar en lo que aporta.

El triage prioriza; no decide si hay incidente.

Fuente: NIST SP 800-61 Rev. 3 (2025).

Fuente: NIST SP 800-61 Rev. 3 (2025); elaboración propia

Triage automático con verificación humana

La máquina ordena la cola; la persona confirma el veredicto y documenta la decisión.

Triage automático con verificación humana



Sin el paso humano, el triage no es una ayuda: es una delegación peligrosa.

El modelo puede marcar lo inofensivo como urgente y dejar pasar lo grave que parece normal.

La trazabilidad de cada decisión mejora el sistema con el tiempo.

Fuente: NIST SP 800-61 Rev. 3 (2025); OWASP LLM Top 10 (2025).

Fuente: NIST SP 800-61 Rev. 3 (2025); OWASP LLM Top 10 (2025) para validación de salidas

Laboratorio 7: cinco pasos y una tabla

Montar, atacar, defender, tabular y cerrar: eso es todo lo que pide la guía, sin pasos escondidos.



1

montar el asistente

EC2, Ollama, secreto

2

lanzar cinco ataques

uno por uno, con captura

3

aplicar tres defensas

y repetir los ataques

4

armar la tabla

ataque por configuración

5

entregar y cerrar

PDF y End Lab

El paso 4 es el decisivo: cada SÍ o NO de la tabla debe coincidir con una captura.

La guía está publicada en el sitio del curso; no hay comandos fuera de ella.

Fuente: guía del Laboratorio 7 — secciones 1 a 6 y rúbrica de entrega

Las cuatro ideas de la semana

Misma tecnología, datos primero, verificación humana y métricas para decidir.



MISMA TECNOLOGÍA

defiende y ataca

decide la intención

y los controles



DATOS PRIMERO

sin telemetría buena

no hay modelo bueno

línea base propia



VERIFICACIÓN

el marco 4D

la IA propone

el humano aprueba



MEDIR

precisión y recuerdo

vigilar la deriva

medir antes de confiar

Este criterio evalúa cualquier herramienta que te vendan como inteligente.

Fuente: elaboración propia; NIST AI RMF 1.0 (2023); OWASP LLM (2025).

Fuente: elaboración propia; NIST AI RMF 1.0 (2023); OWASP LLM (2025)

Cuatro preguntas antes de comprar una solución con IA

Datos que usa, cómo se evalúa, quién decide y cómo se audita: lo que hay que preguntar al proveedor.

Cuatro preguntas al proveedor



¿DATOS?

con qué entrena

y dónde están



¿MÉTRICAS?

precisión y recuerdo

no solo clientes



¿QUIÉN DECIDE?

un humano

responsable



¿AUDITORÍA?

cómo se actualiza

y se revisa

El marco de gestión de riesgos del NIST aplicado a una conversación comercial.

Fuente: NIST AI RMF 1.0 (2023), MAP y MEASURE

Fuente: NIST AI Risk Management Framework 1.0 (2023), funciones MAP y MEASURE; Gartner (2026)

Lo que no debe automatizarse

Decisiones con impacto humano, cambios de política y cierres de incidentes: siempre con persona.

Tres zonas que se reservan a las personas



IMPACTO HUMANO

despidos, bloqueos

o decisiones sobre

personas



POLÍTICA A ESCALA

un error de configuración

expone o paraliza

toda la organización



CIERRE DE INCIDENTE

declarar terminado

exige juicio

y responsabilidad

El modelo sugiere, prioriza y prepara; la decisión con consecuencias la firma una persona.

Niveles de autonomía y supervisión definidos por impacto (NIST AI RMF).

Fuente: NIST AI RMF 1.0 (2023); NIST SP 800-61 Rev. 3 (2025).

REFERENCIAS

Dónde seguir leyendo

Ocho fuentes oficiales para profundizar, todas con la fecha de consulta en la guía del curso.

OWASP LLM Top 10
riesgos de aplicaciones con modelos

MITRE ATT&CK
matriz de ataques clásicos

MITRE ATLAS
ataques a sistemas de IA

NIST AI RMF
gestión de riesgos de IA

NIST SP 800-61r3
respuesta a incidentes

ENISA
panorama de amenazas

CISA
guías y avisos de IA

IC3 (FBI)
reportes de fraude

Todas con fecha de consulta en la guía de la semana.

Fuente: compilación propia de las fuentes citadas durante la semana 14

La semana 15: hacking ético y marco legal

Pasamos a la metodología del hacking ético, siempre con autorización y con enfoque defensivo.

SEMANA 14 · HOY

la defensa aprende

el ataque se automatiza

la IA en la plataforma

mismo conocimiento

SEMANA 15 · SIGUIENTE

hacking ético

alcance autorizado

marco legal colombiano

Nada se hace sobre sistemas ajenos sin autorización escrita · todo el práctico en entorno aislado.

Ley 1273 de 2009: los delitos informáticos tienen marco legal en Colombia.

Fuente: MITRE ATT&CK (2026); OWASP WSTG (2026); Ley 1273 de 2009.

Cómo llegar listo al Laboratorio 7

Vocabulario, flujo y criterio: con eso entras a la guía sin perder tiempo entendiendo de qué habla.

Tres repasos antes de abrir la guía



VOCABULARIO

prompt de sistema

inyección de instrucciones

delimitador y filtro



FLUJO

montar, atacar,

defender, tabular

y cerrar la instancia



CRITERIO

qué control mitiga

y cuál elimina

el riesgo de fuga

Ningún filtro elimina el riesgo: lo elimina no poner el secreto en el prompt.

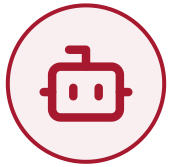
Entra con AWS Academy activo y la guía leída; el resto se hace dentro de la instancia.

Fuente: guía del Laboratorio 7 — secciones 1 a 6; OWASP Top 10 for LLM Applications (2025), LLM01

Qué conviene vigilar en los próximos meses

Agentes autónomos, modelos en el propio dispositivo y detección de contenido sintético.

Tres frentes que conviene vigilar



AGENTES

ejecutan acciones

no solo responden



EN EL DISPOSITIVO

privacidad y datos

dónde se procesan



CONTENIDO SINTÉTICO

reconocer voz, imagen

y video generados

La tecnología avanza más rápido que los marcos de control: por eso el criterio importa.

Fuente: CISA (2026); ENISA Threat Landscape 2024; OWASP LLM (2025)

Fuente: CISA — página de IA (2026); ENISA Threat Landscape 2024; OWASP Top 10 for LLM Applications (2025)

Cierre de la semana 14

La IA amplifica al analista y al atacante: el criterio sigue siendo humano.

La IA no reemplaza al analista: lo amplifica



DEFENSA

NDR que aprende

métricas y límites

triage con verificación



OFENSIVA

phishing creíble

voz y rostro falsos

inyección de instrucciones



CRITERIO

marco 4D

ética profesional

marco legal

Lo que inclina la balanza es la verificación humana y la ética profesional.

Semana 15: hacking ético y marco legal.

Fuente: elaboración propia; NIST AI RMF 1.0 (2023); OWASP LLM (2025); CISA (2026).

Fuente: elaboración propia; NIST AI RMF 1.0 (2023); OWASP LLM (2025); CISA (2026)